

GUIA PARA ENGENHARIA DE REQUISITOS DE PRIVACIDADE DE DADOS (GERPD)

Versão 1.0

Documento oficial consolidado para aplicação

Agosto de 2026

PARTE I – APRESENTAÇÃO DO GUIA

1. Apresentação e objetivo

O Guia para Engenharia de Requisitos de Privacidade de Dados (GERPD) é um instrumento técnico-operacional destinado a apoiar a identificação, a organização, a especificação e a rastreabilidade de requisitos de privacidade em artefatos de Engenharia de Software (ES) relacionados a sistemas que realizam tratamento de dados pessoais. O guia utiliza a OntoPrivacy como base semântica para organizar dados, titulares, agentes, papéis, operações de tratamento e elementos associados à autorização.

A proposta busca reduzir a distância entre a linguagem normativa da privacidade de dados e a linguagem técnica da Engenharia de Requisitos (ER). Para isso, o GERPD estrutura a análise em oito etapas encadeadas, que partem da delimitação do contexto, percorrem dados, participantes, operações, finalidades e condições de tratamento, e resultam na derivação de requisitos, no registro da rastreabilidade e na identificação de lacunas ou pontos de validação.

Objetivo do GERPD: apoiar a identificação, a organização, a especificação, a documentação e a rastreabilidade de requisitos de privacidade em artefatos de Engenharia de Software, utilizando a OntoPrivacy como base semântica e a LGPD e a ISO/IEC 29100 como fundamentos normativos.

Ao final de uma aplicação, as saídas das oito etapas são consolidadas na Matriz Padrão de Aplicação (MPA), preservando os vínculos entre achados, artefatos, conceitos da OntoPrivacy, requisitos, evidências e pontos de validação. O GERPD não constitui mecanismo automático de conformidade; sua função é tornar os aspectos de privacidade mais explícitos, analisáveis e revisáveis no contexto da ER.

2. Público-alvo e formas de utilização

O GERPD destina-se a profissionais envolvidos na identificação, análise, especificação e revisão de requisitos, incluindo engenheiros e analistas de requisitos, desenvolvedores, arquitetos, profissionais de privacidade, segurança da informação, jurídico, governança e representantes do negócio. A composição da equipe depende do escopo da aplicação e das questões que exigirem validação especializada.

- Uso por profissional (individual ou equipe multidisciplinar): um profissional ou equipe responsável percorre as etapas e registra as saídas, encaminhando questões especializadas aos responsáveis competentes.
- Uso apoiado por IA Generativa: uma ferramenta pode analisar os artefatos e produzir as saídas do GERPD, que permanecem preliminares até revisão humana. A utilização de IA Generativa não altera as etapas, os *templates* ou as saídas obrigatórias do GERPD.

- Uso híbrido: atividades de análise e revisão são distribuídas entre profissionais e ferramentas de IA Generativa.

A responsabilidade pela definição do escopo, pelas evidências utilizadas e pela aceitação, correção ou rejeição dos resultados permanece com os responsáveis humanos.

3. Escopo, limitações e responsabilidades

O GERPD concentra-se nas atividades de ER, especialmente elicitación, análise, especificação, documentação, revisão e rastreabilidade de requisitos de privacidade. Pode ser aplicado a um sistema completo ou a um recorte previamente delimitado, como subsistema, funcionalidade, processo, caso de uso ou conjunto de artefatos.

Os resultados estão limitados ao conteúdo e ao nível de detalhamento dos artefatos analisados. A ausência de uma informação não permite concluir que ela inexistia no sistema ou na organização; deve ser registrada como não identificada, a verificar, lacuna ou ponto de validação.

O GERPD não tem como finalidade:

- garantir ou certificar conformidade integral com a LGPD;
- determinar automaticamente bases legais ou condições jurídicas de tratamento;
- substituir análises jurídicas, técnicas, organizacionais, de segurança ou avaliações de impacto;
- comprovar implementação ou efetividade de requisitos e controles;
- atribuir responsabilidades jurídicas apenas a partir de papéis técnicos descritos nos artefatos.

O responsável pela aplicação deve delimitar o objeto, selecionar os artefatos, percorrer as etapas e manter a correspondência entre registros e fontes. Especialistas e partes interessadas devem validar os pontos relacionados às suas competências. Quando houver apoio de IA Generativa, as saídas originais devem ser preservadas e revisadas antes de sua adoção.

PARTE II – FUNDAMENTAÇÃO E VOCABULÁRIO

4. Fundamentos do GERPD

O GERPD foi construído a partir de três bases complementares. A base semântica é fornecida pela OntoPrivacy, que organiza o vocabulário e as relações utilizadas para distinguir dados, pessoas, papéis, tratamentos e operações. A base normativa é composta principalmente pela LGPD e pela ISO/IEC 29100, que fornecem conceitos, princípios, responsabilidades e referências para o tratamento de dados pessoais (Brasil, 2018; ABNT, 2020). A base prática reúne contribuições da ER voltadas à operacionalização de privacidade em artefatos de software, incluindo checklists e inspeção, padrões de requisitos, distinções entre necessidades de negócio e respostas de solução, além de catálogos de requisitos não funcionais (Alves; Neves, 2021; Cerqueira; Mello; Travassos, 2023; Carneiro; Kudo; Bulcão Neto, 2024; Chung et al., 2000; Sousa et al., 2023). Essas contribuições orientam as perguntas, os templates, a derivação de requisitos e a revisão das saídas. Dessa forma, os fundamentos (base semântica, base normativa, base prática) utilizados não apenas sustentam teoricamente o GERPD, mas também orientam sua estrutura, seu processo de uso e seus instrumentos de aplicação.



Figura 1: Fundamentos e construção do GERPD. **Fonte:** Elaborado pelo autor.

Em síntese, a OntoPrivacy fornece a estrutura semântica, a LGPD e a ISO/IEC 29100 delimitam a análise normativa, e as práticas de ER fornecem mecanismos para transformar os achados em registros, requisitos, rastreabilidade e MPA.

5. Vocabulário da OntoPrivacy

A OntoPrivacy fornece o vocabulário controlado utilizado pelo GERPD. O Quadro 1 apresenta apenas os conceitos mais diretamente relacionados ao processo de aplicação; a estrutura completa, as relações e as restrições permanecem no modelo ontológico. Termos normativos ou operacionais que não integrem a ontologia não devem ser apresentados como conceitos da OntoPrivacy.

Conceito	Significado operacional no GERPD
Informação	Elemento informacional geral do domínio.
Dado Pessoal	Informação que se refere a uma Pessoa Natural e a um Titular de Dados Pessoais.
Dado Pessoal Sensível	Especialização de Dado Pessoal referente às categorias sensíveis representadas no domínio.
Dado Anonimizado / Anonimidade	Dado resultante de Anonimização e propriedade associada à sua condição de anonimato.
Pessoa / Pessoa Natural / Pessoa Jurídica	Tipos de pessoas que podem participar do domínio e assumir papéis.
Entidade / Agência / Autoridade Pública	Tipos de entidades que podem participar de situações de tratamento.
Titular de Dados Pessoais	Papel assumido pela Pessoa Natural à qual o Dado Pessoal se refere.
Controlador / Operador / Terceiro	Papéis desempenhados por participantes no contexto do tratamento.
Parte Interessada na Privacidade / Ator / Ator Autorizado / Ator Desautorizado	Papéis gerais e contextuais utilizados para representar participantes envolvidos e sua autorização em determinado tratamento ou operação.
Consentimento	Elemento relacional por meio do qual o titular concede autorização referente a um tratamento.
Tratamento de Dados Pessoais	Estrutura que representa o tratamento realizado sobre dados pessoais.
Tratamento de Dados Pessoais Autorizado	Tratamento representado como autorizado quando houver evidência suficiente.
Operação de Tratamento de Dados Pessoais	Ação específica realizada sobre dados pessoais.
Coleta, Armazenamento, Alteração, Recuperação, Consulta, Divulgação, Disponibilização e Exclusão	Especializações de Operação de Tratamento.
Anonimização / Pseudonimização	Operações de tratamento; Pseudonimização não é classe de dado na versão atual da OntoPrivacy.

Quadro 1: Vocabulário controlado resumido da OntoPrivacy. **Fonte:** Elaborado pelo autor com base na OntoPrivacy.

Categorias como dado acadêmico, dado de contato ou dado financeiro podem ser utilizadas apenas como descrições contextuais. Finalidade, necessidade, base legal, retenção, segurança, requisito funcional ou critério de aceitação também não devem ser registrados como conceitos da OntoPrivacy quando não estiverem representados no modelo.

PARTE III – ORGANIZAÇÃO DA APLICAÇÃO

6. Entradas, papéis e saídas

A aplicação do GERPD requer a definição do objeto e do objetivo da análise, a seleção dos artefatos e a identificação do responsável pela aplicação e pela revisão. As saídas de uma etapa passam a compor as entradas das etapas subsequentes.

Categoria	Elemento	Descrição
Entrada	Objeto e objetivo	Sistema, funcionalidade, processo, serviço ou conjunto de artefatos analisado.
Entrada	Artefatos de ES	Requisitos, casos de uso, histórias, modelos, APIs, regras, políticas e documentos correlatos.
Entrada	OntoPrivacy	Vocabulário semântico para classificação e relacionamento dos achados.
Entrada	Referências normativas	LGPD, ISO/IEC 29100 e outras fontes pertinentes ao contexto.
Papel	Responsável pela aplicação	Delimita o escopo, conduz as etapas e organiza as saídas.
Recurso de apoio	IA Generativa	Recurso opcional para analisar artefatos e produzir saídas a serem revisadas.
Papel	Revisor humano	Verifica evidências, classificações, requisitos e lacunas.
Papel	Partes interessadas / especialistas	Validam questões de negócio, jurídicas, técnicas, organizacionais ou de segurança.
Saída — Etapa 1	Caracterização do contexto	Escopo, objetivo, participantes, artefatos, integrações e limites.
Saída — Etapa 2	Lista de dados pessoais	Dados, localização, classificação e evidência.
Saída — Etapa 3	Mapa de titulares, agentes e papéis	Participantes e papéis identificados ou pendentes.
Saída — Etapa 4	Mapa de operações de tratamento	Dados, funcionalidades, operações, atores e evidências.
Saída — Etapa 5	Finalidades, Autorização e Condições	Finalidade, necessidade, condição autorizadora, acesso e pontos de atenção.
Saída — Etapa 6	Requisitos derivados	Requisitos candidatos e elementos complementares.
Saída — Etapa 7	Matriz de Rastreabilidade	Vínculos dos requisitos com conceitos, fontes, dados, operações, atores e evidências.
Saída — Etapa 8	Pontos de atenção e validação	Lacunas, inconsistências e encaminhamentos.
Consolidação	Matriz Padrão de Aplicação (MPA)	Integra os achados das oito etapas em uma estrutura única.

Quadro 2: Entradas, papéis e saídas do GERPD. **Fonte:** Elaborado pelo autor.

Os requisitos produzidos na Etapa 6 permanecem candidatos até revisão. A Matriz de Rastreabilidade e a MPA são instrumentos distintos: a primeira é produzida na Etapa 7 e é centrada nos requisitos; a segunda consolida todos os tipos de achado após a conclusão das oito etapas.

PARTE IV – PROCESSO DE APLICAÇÃO

7. Visão geral do processo

O GERPD organiza a análise em oito etapas interdependentes. As cinco primeiras constroem o cenário de tratamento: contexto, dados, participantes, operações e finalidades/condições. As três últimas derivam requisitos, registram a rastreabilidade e identificam lacunas ou necessidades de validação.

A dependência é cumulativa: a Etapa 2 utiliza o contexto da Etapa 1; a Etapa 3 considera contexto e dados; a Etapa 4 relaciona dados e participantes às operações; a Etapa 5 examina finalidades e condições; a Etapa 6 deriva requisitos a partir do conjunto anterior; a Etapa 7 registra seus vínculos; e a Etapa 8 revisa a coerência global.

A OntoPrivacy atua transversalmente como base semântica. O processo é iterativo: novos achados podem exigir retorno a etapas anteriores, e as alterações devem ser propagadas às saídas dependentes. Esses retornos integram a mesma aplicação.



Figura 2: Visão geral do processo de aplicação do GERPD. **Fonte:** Elaborado pelo autor.

Após a Etapa 8, as saídas são consolidadas na MPA. Essa consolidação não constitui uma nona etapa. A Matriz de Rastreabilidade permanece como produto específico da Etapa 7 e alimenta a MPA juntamente com as demais saídas.

8. Aplicação detalhada das etapas do GERPD

As subseções seguintes apresentam as oito etapas com a mesma estrutura editorial: objetivo, condições de entrada, entradas necessárias, conceitos envolvidos, perguntas orientadoras, procedimento, template, saída obrigatória, critério de encerramento, retorno e exemplo sintético resumido. O cenário fictício do Portal de Inscrição em Cursos de Extensão é utilizado apenas para ilustração.

8.1 Etapa 1: Delimitar o contexto

A primeira etapa estabelece o recorte no qual os aspectos de privacidade serão analisados, evitando requisitos genéricos ou desconectados do cenário representado nos artefatos.

Objetivo: definir o objeto, o objetivo funcional, os participantes, os artefatos, as integrações e os limites da aplicação.

Condições de entrada: existência de um objetivo inicial e de pelo menos um artefato ou fonte documental que permita compreender o objeto analisado.

Entradas necessárias: objetivo da aplicação; artefatos de ES; informações básicas sobre sistema, processo, usuários e integrações.

Conceitos da OntoPrivacy envolvidos: vínculo predominantemente indireto; Tratamento de Dados Pessoais, Ator e Parte Interessada na Privacidade podem apoiar a compreensão preliminar quando explicitados.

Perguntas orientadoras: qual objeto será analisado? qual seu objetivo funcional? quem participa? quais artefatos e integrações são relevantes? quais limites e indícios de tratamento existem?

Procedimento: identificar a análise (AN-xx); delimitar a unidade de análise; descrever o objetivo funcional; registrar participantes, artefatos e integrações; indicar preliminarmente a existência de tratamento; explicitar limites; preencher o Quadro 3.

Campo	Orientação de preenchimento
ID da análise	Identificador AN-xx.
Sistema ou projeto	Nome e breve descrição.
Funcionalidade, processo ou artefato analisado	Unidade principal da análise.
Objetivo funcional	Resultado funcional esperado.
Usuários, perfis e partes interessadas	Participantes mencionados, sem antecipar papéis jurídicos.
Artefatos utilizados	Documentos, modelos, APIs ou outras fontes.
Integrações relevantes	Sistemas, serviços ou bases externas.
Indicação preliminar de TDP	Sim, Não, Parcial ou A verificar.
Limites da análise	Elementos incluídos e excluídos do escopo.
Observações	Dúvidas ou restrições relevantes.

Quadro 3: Caracterização do contexto da aplicação. **Fonte:** Elaborado pelo autor.

Saída obrigatória: Caracterização do contexto analisado.

Critério de encerramento: o objeto, os artefatos e os limites devem estar definidos em nível suficiente para iniciar o mapeamento dos dados.

Retorno: rever esta etapa quando novos artefatos, integrações ou participantes alterarem o escopo.

Exemplo: AN-01 - Portal de Inscrição em Cursos de Extensão; escopo: inscrição e emissão de certificados; participantes: candidato, equipe administrativa e coordenação; artefatos: requisitos e história de usuário; integração: serviço institucional de e-mail; fora do escopo: pagamentos e ambiente virtual.

8.2 Etapa 2: Mapear os dados pessoais

A etapa identifica informações relacionadas a pessoas naturais e registra localização, classificação, possível titular e evidência. A classificação deve considerar o significado contextual do elemento, não apenas seu nome técnico.

Objetivo: identificar e registrar os dados pessoais presentes nos artefatos, distinguindo a classificação ontológica de categorias meramente descritivas.

Condições de entrada: contexto e limites definidos, com artefatos que permitam localizar elementos informacionais.

Entradas necessárias: Caracterização do contexto; artefatos do escopo; modelos e dicionários de dados; vocabulário da OntoPrivacy.

Conceitos da OntoPrivacy envolvidos: Dado Pessoal, Dado Pessoal Sensível, Dado Anonimizado e, quando pertinente, Anonimização e Pseudonimização como operações.

Perguntas orientadoras: quais elementos se referem a pessoas naturais? há dados sensíveis ou anonimizados? onde aparecem? qual titular está relacionado? há classificação a verificar?

Procedimento: examinar os artefatos; atribuir IDs DP-xx; registrar nome e localização; classificar quando houver evidência; relacionar o titular quando explícito; registrar categoria contextual e evidência; marcar incertezas como A verificar; preencher o Quadro 4.

ID	Dado identificado	Localização	Conceito da OntoPrivacy	Titular	Categoria / observação	Evidência
DP-xx						

Quadro 4: Registro dos dados pessoais identificados. **Fonte:** Elaborado pelo autor.

Saída obrigatória: Lista estruturada de dados pessoais.

Critério de encerramento: os artefatos do escopo foram examinados e os dados identificados possuem localização, classificação ou status A verificar e evidência.

Retorno: rever quando etapas posteriores revelarem novo dado, titular ou evidência de anonimização/pseudonimização.

Exemplo: {(DP-01 | Nome | Dado Pessoal | candidato | identificação nominal); (DP-02 | CPF | Dado Pessoal | candidato | identificador civil); (DP-03 | E-mail | Dado Pessoal | candidato | contato eletrônico. Não foram identificados dados sensíveis ou anonimizados)}.

8.3 Etapa 3: Identificar titulares, agentes e papéis

A etapa relaciona os dados pessoais a pessoas, entidades, usuários, perfis, sistemas ou organizações que participam do contexto, distinguindo o participante e seu papel técnico do papel conceitual da OntoPrivacy.

Objetivo: identificar os participantes e registrar, quando houver evidência, os papéis desempenhados no tratamento.

Condições de entrada: Caracterização do contexto e Lista estruturada de dados pessoais disponíveis.

Entradas necessárias: saídas das Etapas 1 e 2; artefatos sobre usuários, responsabilidades, permissões e integrações; OntoPrivacy.

Conceitos da OntoPrivacy envolvidos: Titular de Dados Pessoais, Controlador, Operador, Terceiro, Ator Autorizado, Ator Desautorizado, Ator e Parte Interessada na Privacidade.

Perguntas orientadoras: a quem os dados se referem? quem decide? quem executa o tratamento? quem acessa ou recebe dados? há participantes cujo papel depende de validação?

Procedimento: identificar participantes; atribuir IDs AG-xx; registrar papel técnico e conceitual separadamente; relacionar dados/operações; classificar apenas com evidência; marcar papéis incertos como A verificar; preencher o Quadro 5.

ID	Ator, perfil ou entidade	Papel no sistema/processo	Conceito da OntoPrivacy	Dados / operações	Evidência	Observação
AG-xx						

Quadro 5: Mapa de titulares, agentes e papéis. **Fonte:** Elaborado pelo autor.

Saída obrigatória: Mapa de titulares, agentes e papéis.

Critério de encerramento: os participantes relevantes foram examinados e as classificações possuem evidência ou estão marcadas como A verificar.

Retorno: rever quando uma operação, integração ou nova informação alterar a interpretação do participante ou do papel.

Exemplo: {(AG-01 | Candidato | Titular de Dados Pessoais); (AG-02 | Instituição promotora | Controlador preliminar, sujeito à confirmação); (AG-03 | Equipe administrativa | Ator Autorizado para consulta, sem atribuição automática de Controlador ou Operador)}.

8.4 Etapa 4: Caracterizar as operações de tratamento

A etapa identifica o que é realizado sobre os dados pessoais e relaciona cada ação às funcionalidades, aos participantes e às evidências. Métodos HTTP, comandos de banco ou nomes de telas não determinam automaticamente uma Operação de Tratamento.

Objetivo: identificar e registrar as Operações de Tratamento de Dados Pessoais realizadas sobre os dados mapeados.

Condições de entrada: dados e participantes identificados em nível suficiente para localizar ações sobre os dados.

Entradas necessárias: saídas das Etapas 1 a 3; requisitos, casos de uso, fluxos, APIs e modelos; OntoPrivacy.

Conceitos da OntoPrivacy envolvidos: Operação de Tratamento de Dados Pessoais; Coleta, Alteração, Armazenamento, Recuperação, Consulta, Divulgação, Disponibilização, Exclusão, Anonimização e Pseudonimização.

Perguntas orientadoras: o que é realizado sobre cada dado? qual operação representa a ação? em qual funcionalidade ocorre? quem participa? a finalidade está explícita?

Procedimento: examinar cada dado; atribuir IDs OP-xx; distinguir ação técnica de operação de tratamento; usar a operação mais específica sustentada; registrar uma operação por linha; relacionar participantes; registrar finalidade somente quando explícita; preencher o Quadro 6.

ID	Funcionalidade / processo	Dado pessoal	Operação de tratamento	Agente / ator	Finalidade explícita	Evidência
OP-xx						

Quadro 6: Mapa de operações de tratamento de dados pessoais. **Fonte:** Elaborado pelo autor.

Saída obrigatória: Mapa de operações de tratamento de dados pessoais.

Critério de encerramento: as operações identificadas possuem dado, funcionalidade, participante e evidência, e finalidades não explicitadas não foram presumidas.

Retorno: rever dados e participantes quando uma operação revelar elementos não registrados ou classificação incorreta.

Exemplo: {(OP-01 | Coleta | envio do formulário Nome, CPF e E-mail); (OP-02 | Armazenamento | registro da inscrição); (OP-03 | Consulta | equipe administrativa consulta inscrições para validação)}.

8.5 Etapa 5: Analisar finalidade, autorização e condições de tratamento

A etapa verifica o que está documentado sobre finalidade, necessidade, consentimento ou outra condição autorizadora e restrição de acesso. Ela não determina automaticamente a base legal nem comprova legitimidade do tratamento.

Objetivo: examinar as finalidades e condições associadas às relações entre dados e operações, registrando ausências e pontos de atenção.

Condições de entrada: Mapa de operações disponível e artefatos capazes de indicar motivação, condições ou restrições do tratamento.

Entradas necessárias: saídas das Etapas 1 a 4; regras de negócio, políticas e especificações; LGPD, ISO/IEC 29100 e OntoPrivacy.

Conceitos da OntoPrivacy envolvidos: Tratamento de Dados Pessoais, Tratamento de Dados Pessoais Autorizado, Consentimento, Ator Autorizado e Ator Desautorizado.

Perguntas orientadoras: a finalidade está explícita? o dado é necessário? há consentimento ou outra condição documentada? existe restrição de acesso? o que precisa ser validado?

Distinções essenciais: finalidade explícita não equivale a autorização; campo obrigatório não comprova necessidade; restrição técnica de acesso não equivale a Consentimento ou autorização jurídica do tratamento.

Procedimento: examinar cada relação dado/operação; atribuir IDs FA-xx; registrar finalidade apenas quando explícita; avaliar a necessidade apenas com base nas evidências; registrar consentimento ou outra condição somente quando documentados; identificar restrições de acesso; registrar pontos de atenção; preencher o Quadro 7.

ID	Dado / Operação	Finalidade está explícita?	Dado necessário?	Consentimento / outra condição?	Restrição de acesso?	Ponto de atenção
FA-xx						

Quadro 7: Finalidades, Autorização e Condições de Tratamento. **Fonte:** Elaborado pelo autor.

Saída obrigatória: Quadro de Finalidades, Autorização e Condições de Tratamento.

Critério de encerramento: as relações relevantes foram examinadas e ausências ou ambiguidades estão registradas sem presunção de finalidade ou condição jurídica.

Retorno: rever dados, participantes ou operações quando a análise revelar elementos omitidos ou incompatíveis.

Exemplo: {(FA-01 | CPF/Coleta | finalidade de inscrição explícita | necessidade A verificar | condição autorizadora A verificar); (FA-02 | E-mail/Coleta | finalidade de confirmação explícita | necessidade Parcial | condição A verificar); (FA-03 | Dados/Consulta | finalidade de validação administrativa explícita | acesso restrito ao perfil administrativo | necessidade dos campos Parcial)}.

8.6 Etapa 6: Derivar requisitos de privacidade

A etapa transforma os achados anteriores em proposições utilizáveis na ER. Requisitos derivados antes da revisão humana devem ser tratados como candidatos, especialmente quando resultarem de lacunas ou decisões ainda pendentes.

Objetivo: formular requisitos candidatos de privacidade e elementos complementares a partir das saídas das Etapas 1 a 5.

Condições de entrada: existência de achados suficientes para justificar uma obrigação, comportamento, qualidade, controle ou condição verificável.

Entradas necessárias: saídas das Etapas 1 a 5; evidências dos artefatos; conceitos da OntoPrivacy; referências normativas.

Conceitos da OntoPrivacy envolvidos: variam conforme o requisito e podem incluir Dado Pessoal, Titular, agentes, Tratamento e Operações de Tratamento. Os tipos de requisito não são conceitos da OntoPrivacy.

Perguntas orientadoras: que obrigação decorre do achado? quem deve atendê-la? sobre quais dados/operações? a proposição está sustentada? como poderá ser verificada?

Procedimento: examinar as saídas anteriores; atribuir IDs RP-xx; explicitar o responsável; formular uma obrigação principal por registro; classificar o tipo de elemento derivado; relacionar a origem; registrar conceitos e ponto de validação; preencher o Quadro 8.

Estrutura preferencial: “O [sistema, organização ou ator] deve [ação ou qualidade] [objeto] [condição aplicável]”. Quando uma lacuna admitir diferentes soluções, deve-se registrar primeiro a necessidade de negócio, evitando escolher prematuramente uma resposta técnica.

ID	Elemento derivado	Tipo de elemento derivado	Origem da derivação	Conceitos da OntoPrivacy	Ponto de validação
RP-xx		Funcional / Não funcional / Negócio / Solução / Controle / Critério de aceitação			

Quadro 8: Registro dos requisitos de privacidade derivados. **Fonte:** Elaborado pelo autor.

Saída obrigatória: Registro dos requisitos de privacidade derivados, tratados como candidatos até revisão.

Critério de encerramento: os principais achados foram examinados, cada proposição possui responsável e origem, e as incertezas estão explicitadas.

Retorno: rever etapas anteriores quando a formulação depender de dado, papel, operação ou condição não registrada.

Exemplo: {(RP-01 | A instituição promotora deve definir e documentar a condição autorizadora aplicável aos tratamentos da inscrição (Negócio)); (RP-02 | A instituição deve documentar a necessidade do CPF para a inscrição (Negócio)); (RP-03 | O portal deve restringir a consulta das inscrições ao perfil administrativo autorizado (Funcional)); (RP-04 | Dado um usuário sem perfil autorizado, o portal deve negar a consulta sem apresentar dados pessoais (Critério de aceitação))}.

8.7 Etapa 7: Registrar a rastreabilidade

A etapa documenta a origem dos requisitos candidatos, relacionando-os a conceitos, fontes, dados, operações, participantes e evidências. A Matriz de Rastreabilidade é produto próprio da Etapa 7 e permanece distinta da MPA.

Objetivo: explicitar a cadeia de vínculos que justifica cada requisito candidato.

Condições de entrada: Registro dos requisitos derivados concluído e identificadores das etapas anteriores disponíveis.

Entradas necessárias: requisitos RP-xx; registros DP-xx, AG-xx, OP-xx e FA-xx; artefatos, evidências, OntoPrivacy e fontes normativas.

Conceitos da OntoPrivacy envolvidos: dependem do requisito rastreado e devem corresponder aos conceitos efetivamente relacionados ao achado.

Perguntas orientadoras: quais conceitos e fontes fundamentam o requisito? quais dados, operações e participantes são afetados? onde está a evidência? os vínculos estão completos?

Procedimento: examinar cada requisito; registrar conceitos e fonte; relacionar dados, operações e atores; indicar artefato/evidência; atribuir status Completo, Parcial ou A validar; preencher o Quadro 9.

ID do requisito	Conceito da OntoPrivacy	Fonte normativa / conceitual	Dado pessoal	Operação	Agente / ator	Artefato / evidência	Status
RP-xx							Completo / Parcial / A validar

Quadro 9: Matriz de Rastreabilidade dos requisitos de privacidade. **Fonte:** Elaborado pelo autor.

Saída obrigatória: Matriz de Rastreabilidade dos requisitos de privacidade.

Critério de encerramento: todos os requisitos candidatos estão presentes e os vínculos aplicáveis foram registrados ou classificados como Parcial/A validar.

Retorno: rever a etapa de origem quando a rastreabilidade revelar dado, papel, operação, finalidade ou requisito inconsistente.

Exemplo: {(RP-03 | Dado Pessoal / Consulta | regra de acesso do caso de uso | status Completo); (RP-04 | critério relacionado a RP-03, com definição incompleta dos perfis | status Parcial); (RP-01 | condição autorizadora ausente nos artefatos | status A validar)}.

8.8 Etapa 8: Validar, revisar e registrar pontos de atenção

A última etapa examina conjuntamente as saídas anteriores para identificar inconsistências resolvíveis, lacunas e necessidades de validação. O termo validar, nesta etapa, significa verificar a coerência da aplicação e indicar o que ainda precisa ser confirmado; a revisão humana formal ocorre posteriormente, na Seção 10.

Objetivo: examinar a coerência das saídas das Etapas 1 a 7 e registrar dúvidas, lacunas, conflitos e necessidades de validação.

Condições de entrada: todas as saídas anteriores, especialmente requisitos candidatos e Matriz de Rastreabilidade.

Entradas necessárias: saídas das Etapas 1 a 7; artefatos e evidências; pontos de validação já registrados.

Conceitos da OntoPrivacy envolvidos: os conceitos utilizados nas etapas anteriores, cuja coerência deve ser revisada sem acrescentar fatos ausentes.

Perguntas orientadoras: há inconsistências? faltam dados, papéis, operações ou condições? há requisito ambíguo ou não rastreável? quais questões exigem validação especializada?

Procedimento: reunir as saídas; verificar correspondência entre registros; corrigir inconsistências sustentadas pelos artefatos; atribuir IDs PA-xx às questões pendentes; classificar tipo e impacto; indicar responsável e encaminhamento; preencher o Quadro 10.

ID	Item relacionado	Descrição	Tipo	Impacto potencial	Responsável pela validação	Encaminhamento
PA-xx			Jurídico / Técnico / Organizacional / Segurança	Alto / Médio / Baixo / A avaliar		

Quadro 10: Registro de pontos de atenção, lacunas e necessidades de validação. **Fonte:** Elaborado pelo autor.

Saída obrigatória: Registro de pontos de atenção, lacunas e necessidades de validação.

Critério de encerramento: as saídas foram examinadas, as inconsistências resolvíveis foram encaminhadas e as pendências possuem tipo, impacto, responsável e ação proposta.

Retorno: retornar à etapa correspondente quando o ponto puder ser resolvido com evidências já disponíveis; caso contrário, mantê-lo para validação especializada.

Exemplo: {(PA-01 | condição autorizadora não identificada | Jurídico/Alto | encaminhar à área jurídica ou privacidade); (PA-02 | necessidade do CPF não justificada | Organizacional/Alto | confirmar com o responsável pelo processo); (PA-03 | escopo de acesso administrativo insuficientemente definido | Segurança/Médio | definir perfis e permissões)}.

PARTE V – CONSOLIDAÇÃO E VALIDAÇÃO

9. Consolidação na MPA

Após a conclusão das oito etapas, as saídas são reunidas na Matriz Padrão de Aplicação (MPA). A consolidação não constitui uma nona etapa; ela integra os achados em uma visão única, preservando os identificadores e as evidências de origem.

9.1 Finalidade da MPA

A MPA tem como finalidade consolidar os achados produzidos durante a aplicação do GERPD, favorecendo sua documentação, integração, rastreabilidade, revisão e síntese. Ela reúne tanto elementos explicitamente identificados quanto lacunas e necessidades de validação, sem substituir os templates das etapas.

A Matriz de Rastreabilidade e a MPA possuem objetos diferentes: a primeira é centrada nos requisitos candidatos e é produzida na Etapa 7; a MPA é produzida posteriormente e consolida todos os tipos de achado.

9.2 Estrutura da MPA

Cada linha da MPA representa um achado de privacidade rastreável: informação relevante que possui origem identificável nas saídas do GERPD e que pode ser relacionada a um artefato, evidência, conceito, participante, operação, requisito ou ponto de validação. Um mesmo elemento técnico pode originar diferentes achados quando houver conclusões semanticamente distintas.

Campo	Descrição
ID do achado	Identificador MPA-xx.
Artefato analisado	Documento, modelo, API, regra ou outra fonte analisada.
Elemento analisado	Funcionalidade, campo, requisito, caso de uso, seção ou elemento localizável.
Achado de privacidade	Conclusão principal consolidada.
Conceito da OntoPrivacy	Conceito(s) efetivamente representado(s) no modelo.
Titular	Titular relacionado, quando identificado.
Agente ou ator	Participante e papel relacionado ao achado.
Operação de tratamento	Operação OP-xx associada ao achado.
Finalidade ou condição de tratamento	Finalidade/condição identificada ou referência FA-xx.
Requisito derivado	Requisito(s) RP-xx relacionado(s), quando aplicável.
Tipo de elemento derivado	Funcional, não funcional, negócio, solução, controle ou critério de aceitação.
Fonte normativa ou conceitual	LGPD, ISO/IEC 29100, OntoPrivacy ou outra fonte utilizada.
Evidência no artefato	Localização ou descrição objetiva que sustenta o achado.
Ponto de atenção	PA-xx ou descrição resumida da pendência.
Status da revisão	Não revisado, Aceito, Aceito com ajustes, Rejeitado ou Pendente de validação.

Quadro 11: Campos da Matriz Padrão de Aplicação (MPA). **Fonte:** Elaborado pelo autor.

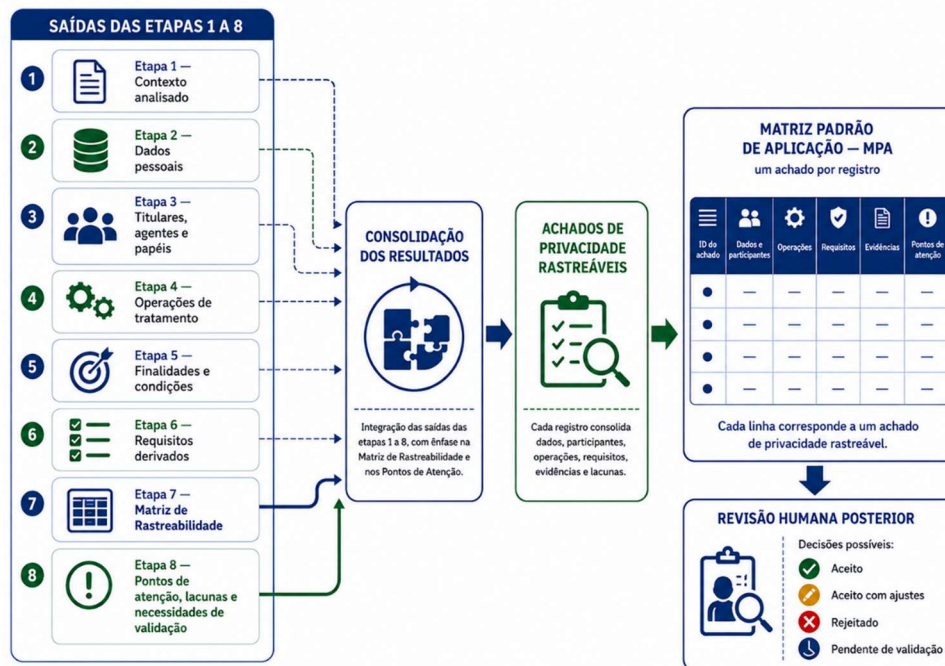


Figura 3: Estrutura e formação da Matriz Padrão de Aplicação (MPA). **Fonte:** Elaborado pelo autor.

9.3 Regras de preenchimento

1. Cada registro deve representar um achado principal; conclusões independentes devem ser separadas.
2. Os identificadores das etapas (DP-xx, AG-xx, OP-xx, FA-xx, RP-xx e PA-xx) devem ser preservados; MPA-xx identifica apenas o registro consolidado.
3. Todo achado deve possuir evidência ou registrar explicitamente a ausência da informação procurada.
4. Somente conceitos efetivamente presentes na OntoPrivacy devem ser registrados no campo ontológico.
5. Informações ausentes não devem ser preenchidas por suposição; devem permanecer como Não identificado, A verificar, Não aplicável, lacuna ou ponto de validação.
6. Achado e requisito são elementos distintos: o achado registra o que foi observado; o requisito expressa uma obrigação candidata derivada.
7. Os vínculos detalhados dos requisitos permanecem na Matriz de Rastreabilidade; a MPA registra a relação consolidada entre o requisito e o achado.
8. Status de rastreabilidade e status de revisão não se confundem. A saída original deve ser preservada, especialmente em aplicações apoiadas por IA Generativa.

Na Matriz de Rastreabilidade, os status são Completo, Parcial e A validar. Na MPA, os registros iniciam como Não revisados e, após revisão humana, podem ser Aceitos, Aceitos com ajustes, Rejeitados ou permanecer Pendentes de validação.

9.4 Exemplo resumido de consolidação

O exemplo abaixo reúne três achados do cenário fictício do Portal de Inscrição em Cursos de Extensão. Para legibilidade, os quinze campos canônicos são apresentados em orientação transposta; a estrutura oficial da MPA permanece a definida na Subseção 9.2.

Campo	MPA-01: Dado pessoal associado a lacuna de necessidade	MPA-02: Restrição de acesso explicitamente documentada	MPA-03: Ausência de condição autorizadora
ID do achado	MPA-01	MPA-02	MPA-03
Artefato analisado	Documento de requisitos	Documento de requisitos / caso de uso de consulta	Documento de requisitos e regras do processo
Elemento analisado	Formulário de inscrição (CPF)	Regra de acesso às inscrições	Coleta, armazenamento e consulta dos dados de inscrição
Achado de privacidade	O CPF é Dado Pessoal coletado obrigatoriamente, mas sua necessidade não está justificada.	A consulta das inscrições é restrita ao perfil administrativo autorizado.	Os artefatos explicitam finalidades operacionais, mas não identificam Consentimento ou outra condição autorizadora.
Conceito da OntoPrivacy	Dado Pessoal; Coleta	Dado Pessoal; Ator Autorizado; Consulta	Tratamento de Dados Pessoais
Titular	AG-01 - Candidato	AG-01 - Candidato	AG-01 - Candidato
Agente ou ator	AG-02 - Instituição promotora	AG-03 - Equipe administrativa	AG-02 - Instituição promotora; AG-03 - Equipe administrativa
Operação de tratamento	OP-01 - Coleta	OP-03 - Consulta	OP-01 a OP-03
Finalidade ou condição	FA-01 - inscrição explícita; necessidade e condição a verificar	FA-03 - validação administrativa; acesso restrito	Finalidades explícitas; condição autorizadora a verificar
Requisito derivado	RP-02 - documentar a necessidade do CPF	RP-03 - restringir consulta ao perfil autorizado; RP-04 - critério de aceitação	RP-01 - definir e documentar a condição autorizadora aplicável
Tipo de elemento derivado	Negócio	Funcional; Critério de aceitação	Negócio
Fonte normativa / conceitual	LGPD - necessidade; ISO/IEC 29100; OntoPrivacy	LGPD - segurança; ISO/IEC 29100; OntoPrivacy	LGPD; ISO/IEC 29100; OntoPrivacy
Evidência	CPF obrigatório no formulário sem justificativa específica.	Caso de uso limita a consulta ao perfil administrativo.	Documentos descrevem as operações, mas não a condição autorizadora.
Ponto de atenção	PA-02 - confirmar necessidade do CPF.	PA-03 - definir detalhadamente perfis e permissões.	PA-01 - identificar e documentar a condição aplicável.
Status da revisão	Não revisado	Não revisado	Não revisado

Os exemplos demonstram que a MPA pode registrar tanto evidências positivas quanto lacunas. Em MPA-03, por exemplo, a conclusão é limitada aos artefatos analisados: não se afirma que a condição autorizadora inexistia no processo real, apenas que ela não foi identificada nos documentos disponíveis.

10. Validação e revisão humana

A revisão humana ocorre após a consolidação inicial da MPA. Sua finalidade é verificar evidências, classificações conceituais, coerência entre as etapas, formulação dos requisitos e vínculos de rastreabilidade. A Etapa 8 identifica o que precisa ser validado; a revisão posterior registra a decisão sobre os achados.

O responsável pela aplicação pode realizar a revisão inicial, mas questões jurídicas, de negócio, técnicas, organizacionais ou de segurança devem ser encaminhadas aos profissionais competentes. O revisor não deve confirmar decisões que ultrapassem sua competência.

As saídas originais devem ser preservadas. Em aplicações apoiadas por IA Generativa, recomenda-se manter separadas a resposta original e a versão revisada. A revisão pode produzir quatro decisões:

- Aceito: o achado está sustentado e não necessita de alteração.
- Aceito com ajustes: o conteúdo principal é mantido, mas classificação, formulação, evidência ou vínculo é corrigido ou complementado.
- Rejeitado: o achado não possui sustentação suficiente, está fora do escopo ou apresenta erro conceitual.
- Pendente de validação: a decisão depende de informação adicional ou de especialista/parte interessada.

Um achado aceito pode continuar relacionado a um ponto de atenção aberto. A revisão da MPA não comprova conformidade integral com a LGPD; apenas registra a decisão humana sobre os resultados produzidos pelo GERPD.

11. Critérios de qualidade

Os critérios de qualidade apoiam a análise qualitativa das saídas do GERPD. A avaliação deve considerar o escopo e as informações efetivamente disponíveis; registrar corretamente uma ausência pode representar um resultado adequado da aplicação.

Critério	Definição breve	Pergunta de verificação
Compleitude	Cobertura das dimensões pertinentes e registro das ausências relevantes.	As principais informações sustentadas pelos artefatos foram identificadas e as lacunas foram explicitadas?
Correção conceitual	Uso adequado dos conceitos e distinções da OntoPrivacy.	As classificações são compatíveis com a OntoPrivacy e evitam confusões conceituais?
Rastreabilidade	Vínculos entre achados, requisitos, artefatos, evidências, conceitos e fontes.	É possível localizar e compreender a origem de cada achado ou requisito?
Utilidade	Potencial das saídas para apoiar análise, especificação, revisão e decisão em ER.	Os resultados podem ser aproveitados ou refinados pelos responsáveis pela ER?
Clareza	Organização, objetividade e compreensibilidade das saídas.	É possível compreender o que foi identificado, por que foi registrado e o que ainda precisa ser validado?

Quadro 12: Critérios de qualidade das saídas do GERPD. **Fonte:** Elaborado pelo autor.

Os critérios analisam a qualidade da aplicação e das saídas produzidas. Eles não comprovam conformidade jurídica, eficácia geral do GERPD, usabilidade do guia ou desempenho de uma ferramenta de IA Generativa. Não é obrigatória a produção de uma pontuação agregada.

Referências

- ABNT — ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. ABNT NBR ISO/IEC 29100:2020. Tecnologia da informação — Técnicas de segurança — Estrutura de privacidade. Rio de Janeiro: ABNT, 2020.
- ALVES, Carina; NEVES, Mariana. Especificação de Requisitos de Privacidade em Conformidade com a LGPD: resultados de um estudo de caso. In: Anais do WER21 — Workshop em Engenharia de Requisitos. Brasília, Brasil: Editora PUC-Rio, 2021.
- BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, DF, 2018.
- CARNEIRO, Cinara Gomes de Melo; KUDO, Taciana N.; BULCÃO NETO, Renato F. Um método para transformação de requisitos legais em padrões de requisitos de software: um estudo com a LGPD. 2024.
- CERQUEIRA, Diego André; MELLO, Rafael Maiani de; TRAVASSOS, Guilherme Horta. Um checklist para inspeção de privacidade e proteção de dados pessoais em artefatos de software. 2023.
- CHUNG, Lawrence; NIXON, Brian A.; YU, Eric; MYLOPOULOS, John. Non-Functional Requirements in Software Engineering. Boston: Kluwer Academic Publishers, 2000.
- SOUSA, Henrique Prado de Sá; ALMENTERO, Eduardo Kinder; CLASSE, Tadeu Moreira de; SANTOS, Rodrigo Julião dos; LEITE, Julio Cesar Sampaio do Prado. Uma abordagem baseada no Catálogo de Requisitos Não Funcionais para conformidade à LGPD. In: Proceedings of the 26th Workshop on Requirements Engineering (WER23). Porto Alegre, 2023. DOI: 10.29327/1298356.26-8.